Third-Party Vendor Risk Assessment

April 2026

Third-Party Vendor Risk Assessment

This assessment evaluates the cybersecurity and operational risk associated with onboarding a third-party cloud service provider. The objective is to identify risks related to data security, access control, compliance, and vendor reliability, and to recommend mitigation strategies aligned with industry best practices.

Vendor Criticality: High (Handles sensitive data and core business operations)

Vendor Risk

Risk ID	Risk Area	Description	Likelihood (1–5)	Impact (1–5)	Risk Score	Risk Level	Control Gap	Recommendation	Status
V-01	Data Security	Vendor may experience a breach exposing sensitive data	3	5	15	High	Lack of encryption standards	Require encryption, SOC 2 compliance	Open
V-02	Access Management	Vendor may not enforce strong authentication controls	3	4	12	Medium	No MFA requirement	Require MFA and RBAC	Open
V-03	Compliance	Vendor may not meet regulatory/security standards	3	5	15	High	No formal certifications	Require ISO 27001 / SOC 2	Open
V-04	Monitoring	Vendor lacks sufficient logging and monitoring capabilities	2	4	8	Medium	No centralized logging	Require SIEM/logging integration	Open
V-05	Data Protection	Data may be stored insecurely or in unknown regions	3	4	12	Medium	No data residency controls	Require encryption + location controls	Open
V-06	Incident Response	Vendor may not respond effectively to security incidents	2	5	10	Medium	No IR plan or SLA	Require incident response plan and SLA	Open

Risk Evaluation **Summary**

The vendor presents moderate to high risk across key areas, including data security, compliance, and incident response. The highest risks are associated with potential data breaches and a lack of compliance certifications, which could result in regulatory and reputational impact.

Recommendation

It is recommended to proceed with the vendor only if security requirements are contractually enforced. These include multi-factor authentication, encryption, logging and monitoring capabilities, and defined incident response obligations.

Assessment **Outcome**

Assessment Outcome: Conditional Approval